

Supplier Information Security Questionnaire (Completed Example)

Northstar Labs – Completed Vendor Security Assessment

This document represents a completed supplier information security questionnaire submitted by Northstar Labs as part of a third-party vendor security assessment process. The responses below are intended to simulate a realistic enterprise ISQ submission.

Supplier Name	Northstar Labs
Industry	Software Development & AI Solutions
Headquarters	Manchester, United Kingdom
Employees	48
Primary Hosting Provider	Microsoft Azure
Document Version	1.0
Completion Date	18 May 2026

1. Do you maintain a formal information security policy?

Yes. Northstar Labs maintains a formal Information Security Policy which is reviewed annually and approved by senior leadership. The policy covers access control, encryption, acceptable use, security responsibilities, asset management, and incident management.

2. Is multi-factor authentication (MFA) enforced for critical systems?

Yes. Multi-factor authentication is mandatory for all cloud platforms, VPN access, source control systems, CI/CD tooling, administrative accounts, and customer production environments. Authenticator applications and hardware security keys are preferred.

3. How is customer data protected?

Customer data is encrypted both in transit and at rest using industry-standard encryption mechanisms including TLS 1.2+ and AES-256. Access to customer data is restricted based on least privilege principles. Production access is logged and monitored.

4. Describe your employee onboarding and offboarding process.

User access is provisioned based on role requirements and approved by management. Access reviews are conducted quarterly. When employees leave the organisation, access to systems and repositories is revoked promptly through a formal offboarding process. Company devices are returned and accounts are disabled immediately.

5. Do you perform vulnerability scanning?

Yes. Automated vulnerability scanning is performed across infrastructure, container images, cloud environments, and software dependencies. Security tooling includes dependency scanning, static analysis, and infrastructure vulnerability assessments integrated into CI/CD pipelines. High severity vulnerabilities are prioritised for remediation.

6. Are penetration tests performed?

Yes. Penetration testing is performed periodically on customer-facing applications and critical infrastructure environments. External third-party security specialists may be engaged for independent assessments. Findings are documented and tracked through remediation.

7. Describe your backup and disaster recovery process.

Production systems and databases are backed up regularly using encrypted cloud backups. Backups are retained according to operational and compliance requirements. Northstar Labs maintains documented disaster recovery procedures and conducts periodic recovery testing. Current recovery objectives: • RTO: 4 hours • RPO: 1 hour

8. How do you handle security incidents?

Northstar Labs maintains a formal Incident Response Policy. Employees are required to report suspected incidents immediately. Incidents are categorised by severity and managed through defined containment, eradication, recovery, and post-incident review processes. Regulatory and customer notifications are handled in accordance with contractual and legal obligations.

9. Are employees provided with security awareness training?

Yes. All employees complete annual security awareness training covering phishing, password security, data handling, social engineering, and secure remote working practices. Additional training is provided to engineering teams on secure software development practices.

10. Where is customer data stored?

Customer data is primarily stored within Microsoft Azure regions located in the United Kingdom and European Economic Area (EEA). Cross-border data transfers are controlled in accordance with UK GDPR requirements.

11. Do you follow a secure software development lifecycle (SDLC)?

Yes. Northstar Labs follows a secure SDLC that incorporates security considerations throughout planning, design, development, testing, deployment, and maintenance activities. Code reviews, automated testing, secrets scanning, and dependency analysis are integrated into development workflows.

12. Do you allow Bring Your Own Device (BYOD)?

BYOD access is permitted only for approved devices that meet minimum security requirements including encryption, password protection, and updated operating systems. Company data on personal devices remains subject to company security controls.